

Engineering Document E05 — API Engineering Specification

Product Name: HQ

Engineering Package: Version 1.0

Purpose

This document defines the official REST API specification for HQ.

The API acts as the communication layer between the web application, future mobile application, internal services, and the AI orchestration engine.

All APIs must be consistent, secure, versioned, documented, and fully testable.

API Principles

Every API must be:

- RESTful
 - Stateless
 - Secure
 - Versioned
 - Type-safe
 - Documented
 - Predictable
 - Idempotent where appropriate
-

Base URL

`https://api.hq.ai/v1`

Development:

`http://localhost:3001/api/v1`

Authentication

Authentication uses **Firestore Authentication**.

Clients send:

`Authorization: Bearer <Firestore_ID_Token>`

The backend verifies the token before processing the request.

Standard Response Format

Success

```
{
  "success": true,
  "message": "Mission created successfully.",
  "data": {},
  "meta": {}
}
```

Error

```
{
  "success": false,
  "message": "Validation failed.",
  "error": {
    "code": "VALIDATION_ERROR",
    "details": []
  }
}
```

Every endpoint follows this response format.

API Modules

The API is organized into feature modules.

- Authentication
- Users
- Organizations
- Headquarters
- Executives
- Missions
- AI
- Prompts
- Memory
- Assets
- Billing
- Analytics
- Notifications
- Admin
- Settings
- Audit

Authentication Endpoints

POST /auth/login
POST /auth/logout
POST /auth/refresh
GET /auth/me

Responsibilities:

- Verify Firebase token
- Create session
- Return authenticated user
- Manage logout

User Endpoints

GET /users/me
PATCH /users/me
DELETE /users/me

Future:

GET /users
GET /users/:id

(Admin only)

Organization Endpoints

POST /organizations
GET /organizations/:id
PATCH /organizations/:id
DELETE /organizations/:id

Additional:

GET /organizations/current

Headquarters Endpoints

POST /headquarters
GET /headquarters
PATCH /headquarters/:id

Responsibilities:

- Workspace creation
 - Branding
 - Configuration
-

Executive Endpoints

GET /executives

GET /executives/:id

GET /executives/activity

POST /executives/chat

POST /executives/assign

These endpoints manage the Executive Board.

Mission Endpoints

POST /missions

GET /missions

GET /missions/:id

PATCH /missions/:id

DELETE /missions/:id

Mission actions:

POST /missions/:id/start

POST /missions/:id/pause

POST /missions/:id/resume

POST /missions/:id/cancel

POST /missions/:id/review

AI Endpoints

POST /ai/execute

POST /ai/chat

POST /ai/generate

GET /ai/status

Only the AI module communicates directly with Gemini.

Prompt Endpoints

GET /prompts

POST /prompts

PATCH /prompts/:id

GET /prompts/:id

Admin access only.

Memory Endpoints

GET /memory

POST /memory

DELETE /memory/:id

Supports:

- Session Memory
 - Mission Memory
 - Executive Memory
-

Asset Endpoints

POST /assets/upload

GET /assets

GET /assets/:id

DELETE /assets/:id

Future:

POST /assets/folders

Billing Endpoints

GET /billing/plans

POST /billing/subscribe

POST /billing/cancel

GET /billing/history

GET /billing/invoices

Analytics Endpoints

GET /analytics/dashboard

GET /analytics/missions

GET /analytics/executives

GET /analytics/usage

Notification Endpoints

GET /notifications

PATCH /notifications/read

DELETE /notifications/:id

Settings Endpoints

GET /settings

PATCH /settings

Admin Endpoints

Restricted to administrators.

GET /admin/users

GET /admin/organizations

GET /admin/system

GET /admin/analytics

Audit Endpoints

GET /audit/logs

Admin only.

Pagination

Collections support:

?page=1

&limit=20

&sort=createdAt

&order=desc

Cursor pagination may be introduced for high-volume resources.

Filtering

Supported query examples:

?status=ACTIVE

?role=CEO

?search=marketing

?createdAfter=2026-01-01

Validation

Every request validates:

- Body
- Parameters
- Query

- Headers

Invalid requests return HTTP 400.

Authorization

RBAC Roles:

- Owner
- Admin
- Member
- Viewer

Permissions are enforced by NestJS Guards.

Rate Limiting

Examples:

Authentication:

5 requests/minute

AI Generation:

30 requests/minute

General API:

120 requests/minute

Limits may vary by subscription plan.

File Upload

Supported formats:

- PNG
- JPG
- SVG
- PDF
- DOCX
- MP4

Uploads include:

- Validation
 - Virus scanning (future)
 - Metadata extraction
 - Storage registration
-

Webhooks

Future webhook events:

- Subscription updated
- Payment succeeded
- Mission completed
- Asset generated
- Organization invited

Webhook payloads are signed for verification.

API Documentation

Swagger automatically generates:

- Endpoints
- DTOs
- Authentication

- Request examples
- Response examples

OpenAPI serves as the API contract.

Versioning

Current:

/v1

Future:

/v2

Older versions remain supported during migration windows.

Error Codes

Standardized codes:

- VALIDATION_ERROR
- UNAUTHORIZED
- FORBIDDEN
- NOT_FOUND
- CONFLICT
- RATE_LIMITED
- INTERNAL_ERROR
- AI_PROVIDER_ERROR

Applications should rely on error codes rather than messages.

Logging

Each request logs:

- Request ID
- User ID
- Organization ID
- Endpoint
- Duration
- Status code

Logs support debugging and monitoring.

Security

Every endpoint must enforce:

- Authentication
- Authorization
- Input validation
- Secure headers
- Rate limiting
- Audit logging

Sensitive endpoints require additional authorization checks.

API Success Criteria

The API Engineering Specification succeeds when:

- Every endpoint follows consistent conventions.
 - Authentication is secure.
 - Validation is comprehensive.
 - Documentation is automatically generated.
 - Mobile and web clients share the same contract.
 - New endpoints integrate without breaking existing clients.
-

Conclusion

The HQ API Engineering Specification defines a production-ready REST API that is secure, modular, and scalable.

By standardizing endpoint design, authentication, validation, response formats, versioning, and documentation, HQ establishes a stable API contract that supports rapid frontend development, reliable integrations, and future platform growth.